

Modelo de Encuesta Integral OCTAVE Nacional

Versión 1.0 – Diseñada para responsables de ciberseguridad, riesgos, continuidad de negocio y dirección en organizaciones españolas (operadores esenciales, importantes y demás empresas con vocación de seguir existiendo mañana).

1. Instrucciones generales para la persona encuestada

- La encuesta está orientada a entender cómo gestiona su organización los riesgos de ciberseguridad, siguiendo la lógica OCTAVE (activos, amenazas, vulnerabilidades, riesgos, controles y resultados).
- No se buscan respuestas "políticamente correctas", sino una fotografía honesta que permita mejorar. Una realidad incómoda puntúa más que una ficción heroica.
- Cuando dude entre dos opciones, elija la que mejor refleje la práctica real, no el PowerPoint ideal.
- En las preguntas tipo Likert, use esta referencia general, salvo que se indique otra escala:
- 1 = Inexistente o puramente reactivo.
- 2 = Inicial / ad-hoc.
- 3 = Definido pero irregular.
- 4 = Gestionado y medido.
- 5 = Optimizado / integrado en negocio.

2. Bloque A – Datos de la organización

A.1. Tipo principal de organización

(seleccione la opción que mejor describa su realidad)

- Operador de servicios esenciales según NIS2 (energía, transporte, salud, agua, banca, etc.).
- Entidad importante según NIS2 (otros sectores regulados).
- Administración pública (AGE, autonómica, local, organismo público).
- Empresa privada no sujeta directamente a NIS2 pero con servicios críticos para terceros.
- PYME con alto grado de digitalización.
- Otra (especificar).

A.2. Tamaño aproximado de la organización (empleados/as)

- Menos de 50.
- De 50 a 249.
- De 250 a 999.
- De 1.000 a 4.999.
- 5.000 o más.

A.3. Rol principal de quien responde

- CISO / Responsable de Seguridad de la Información.
- Responsable de Riesgos / Compliance.
- Responsable de Sistemas / Infraestructuras.
- Dirección general / miembro del órgano de gobierno.
- Responsable de continuidad de negocio / resiliencia.
- Otro (especificar).

A.4. Ámbito geográfico principal de operación

- Solo España.
- España y otros países de la UE.
- Global (incluye países fuera de la UE).

3. Bloque B – Gobernanza, estrategia y apetito de riesgo

B.1. Existencia de una estrategia formal de ciberseguridad alineada con la estrategia de negocio

(escala 1–5)

•

No existe estrategia formal; la ciberseguridad es un conjunto de buenas intenciones y fuegos apagados.

•

Existe un documento, pero pocos lo han leído y menos aún lo recuerdan.

•

Estrategia definida y aprobada, conocida por los equipos clave.

•

Estrategia alineada con objetivos de negocio, revisada periódicamente.

•

Estrategia integrada en la planificación estratégica y en la gestión de riesgos corporativos.

1. No existe estrategia formal; la ciberseguridad es un conjunto de buenas intenciones y fuegos apagados.
2. Existe un documento, pero pocos lo han leído y menos aún lo recuerdan.
3. Estrategia definida y aprobada, conocida por los equipos clave.
4. Estrategia alineada con objetivos de negocio, revisada periódicamente.
5. Estrategia integrada en la planificación estratégica y en la gestión de riesgos corporativos.

B.2. Aprobación y supervisión de la estrategia de ciberseguridad por el órgano de gobierno

- No se discute en órganos de gobierno; se trata como asunto puramente técnico.
- Se informa de forma ocasional, normalmente tras incidentes.
- Se presenta y aprueba al menos una vez al año.
- Se revisa periódicamente, con indicadores clave y decisiones de inversión.

B.3. Existencia de una declaración formal de apetito de riesgo en ciberseguridad

- No existe; el apetito de riesgo se mide por el número de noches en vela del CISO.
- Se comenta en reuniones, pero no hay documento aprobado.
- Existe documento aprobado, pero con poca difusión.
- Existe, se comunica a los responsables y se utiliza para priorizar inversiones.
- Existe, se revisa con regularidad y se conecta con métricas cuantitativas de riesgo.

B.4. Integración de la gestión de riesgos de ciberseguridad en el marco de Enterprise Risk Management (ERM)

- La ciberseguridad vive en una galaxia aparte del resto de riesgos.
- Se menciona en el mapa de riesgos, pero sin metodología homogénea.
- Se integra parcialmente en el ERM, con algunos riesgos cibernéticos formalizados.
- Está plenamente integrada, con riesgos cibernéticos evaluados y priorizados junto a los demás.

B.5. Estructura de gobernanza para ciberseguridad

(marque todas las que apliquen)

- Comité específico de seguridad de la información / ciberseguridad.
- Comité de riesgos corporativos con representación de ciberseguridad.
- Reporting periódico del CISO a la alta dirección.
- Reporting periódico del CISO al órgano de gobierno.
- Ninguna de las anteriores; la gobernanza es más bien artesanal.

4. Bloque C – Identificación y gestión de activos (visión OCTAVE Allegro)

C.1. Inventario de activos de información críticos

- No existe inventario formal; los activos críticos se identifican por el ruido que hacen al fallar.
- Existen inventarios parciales y no homogéneos.
- Existe un inventario central, pero incompleto o poco actualizado.
- Existe inventario central, con clasificación de criticidad y responsables asignados.
- Existe inventario central, con dependencias documentadas y sincronización con CMDB / herramientas de gestión.

C.2. Cobertura del inventario sobre activos relacionados con servicios esenciales y procesos críticos

- Menos del 25 % de los activos relevantes.
- Entre el 25 % y el 50 %.
- Entre el 50 % y el 75 %.
- Más del 75 %.
- No se dispone de estimación.

C.3. Clasificación de activos según criterios de impacto (negocio, regulatorio, reputacional, etc.)

- No se utiliza clasificación formal de impacto.
- Existe clasificación, pero solo para algunos sistemas.
- Se aplica una clasificación básica (por ejemplo, alto/medio/bajo) a la mayoría de activos.
- Se utilizan criterios de impacto detallados (continuidad, económico, reputación, cumplimiento, personas) alineados con ENS/NIS2.

C.4. Identificación de contenedores de activos (personas, papel, sistemas, redes, proveedores)

- No se identifican explícitamente; se asume que "están en algún servidor".
- Se identifican de forma parcial (principalmente sistemas y redes).
- Se identifican contenedores físicos, lógicos y de terceros para activos críticos.
- Se mantiene un modelo de contenedores actualizado y utilizado en los análisis de riesgo.

C.5. Revisión y actualización del inventario de activos críticos

- Solo después de incidentes o auditorías.
- De forma esporádica, sin calendario claro.
- Al menos una vez al año.
- De forma continua, integrada en procesos de cambio y gestión de activos.

5. Bloque D – Criterios de impacto, medición del riesgo y OCTAVE

D.1. Existencia de criterios formales de impacto para incidentes de ciberseguridad

- No; aplicamos "bajo, medio, alto" por inspiración divina.
- Sí, pero de forma limitada a algunos sistemas o proyectos.
- Sí, con criterios documentados, pero aplicados de forma irregular.
- Sí, criterios documentados y alineados con ENS, NIS2 y la estrategia corporativa.

D.2. Dimensiones de impacto consideradas habitualmente

(marque todas las que se utilicen de forma sistemática)

- Interrupción de servicio / continuidad del negocio.
- Impacto económico directo (costes, pérdida de ingresos).
- Impacto reputacional / imagen.
- Impacto en cumplimiento normativo / sanciones.
- Impacto en derechos de los interesados (por ejemplo, protección de datos personales).
- Impacto en salud y/o seguridad física de las personas.
- Otras (especificar).

D.3. Escala utilizada para cuantificar el impacto

- Solo descriptores cualitativos (bajo/medio/alto).
- Escalas cualitativas enriquecidas con ejemplos numéricos (pérdidas aproximadas, duración, número de personas afectadas).
- Escalas claramente cuantificadas (rangos de pérdidas, tiempos, volumen de datos, etc.).

D.4. Estimación de probabilidad / frecuencia de los escenarios de riesgo

- Se estima de forma subjetiva, sin criterios comunes.
- Se utilizan escalas cualitativas con descriptores (raro, posible, probable, etc.).
- Se utilizan datos históricos de incidentes propios.
- Se combinan datos internos con datos sectoriales / nacionales (INCIBE, ENISA, etc.).

D.5. Uso de OCTAVE (clásico, Allegro o FORTE) u otras metodologías estructuradas

- No se utiliza ninguna metodología formal; el análisis es más bien artesanal.
- Se utiliza puntualmente OCTAVE para algunos proyectos o sistemas.
- Se utiliza OCTAVE de forma sistemática en la organización.
- Se combinan OCTAVE y otras metodologías (ISO 27005, MAGERIT, FAIR, etc.) en un marco integrado.

6. Bloque E – Vulnerabilidades, amenazas y superficie de ataque

E.1. Gestión de vulnerabilidades técnicas en sistemas críticos

- No existe proceso formal; se parchea cuando el tiempo y los dioses lo permiten.
- Se gestionan vulnerabilidades críticas de forma reactiva.
- Existe proceso documentado con priorización por criticidad.
- Existe proceso automatizado, con métricas de tiempo de parcheo y cobertura.

E.2. Alcance de la gestión de vulnerabilidades

- Solo sistemas on-premise.
- Sistemas on-premise y principales servicios en la nube.
- Sistemas internos, nube y principales terceros clave (cuando es posible contractualmente).

E.3. Monitorización de exposición externa y superficie de ataque

- No se realiza de forma sistemática.
- Escaneos puntuales o como parte de proyectos.
- Escaneos periódicos y seguimiento de hallazgos.
- Programa formal de gestión de superficie de ataque, con métricas y reporting periódico.

E.4. Uso de fuentes de inteligencia de amenazas (threat intelligence)

- No se utilizan fuentes estructuradas.
- Se consumen avisos públicos (por ejemplo, INCIBE-CERT, CCN-CERT, fabricantes).
- Se combinan fuentes públicas con servicios comerciales.
- Se integra la inteligencia de amenazas en los procesos de detección y respuesta.

E.5. Prioridad relativa de las principales categorías de amenazas para su organización (ordenar de 1 a 5, donde 1 = máxima prioridad)

- Ransomware y cifrado de datos.
- Compromiso de cuentas y credenciales.
- Ataques a la disponibilidad (DDoS, sabotaje, etc.).
- Exfiltración / fuga de datos.
- Fraude y estafas dirigidas (phishing avanzado, BEC, etc.).

7. Bloque F – Incidentes, continuidad y resiliencia

F.1. Registro y clasificación de incidentes de ciberseguridad

- Solo se registran casos muy graves o mediáticos.
- Se registran incidentes relevantes, pero sin taxonomía homogénea.
- Se registran y clasifican incidentes con criterios básicos (tipo, impacto, servicio afectado).
- Existe un sistema de gestión de incidentes con taxonomía común y métricas (MTTD, MTTR, etc.).

F.2. Coordinación con CSIRTs / CERTs competentes (INCIBE-CERT, CCN-CERT, sectoriales)

- Solo en casos excepcionales o por imposición regulatoria.
- De forma reactiva, cuando un incidente se desborda.
- De acuerdo con procedimientos definidos para determinados supuestos.
- Con procedimientos claros, canales establecidos y ejercicios periódicos.

F.3. Existencia de planes de respuesta a incidentes de ciberseguridad

- No existen; se improvisa según el incidente.
- Existen borradores o documentos poco usados.
- Existen planes aprobados y conocidos por los equipos clave.
- Existen planes probados mediante simulacros periódicos, con lecciones aprendidas incorporadas.

F.4. Integración de ciberseguridad en los planes de continuidad de negocio y recuperación ante desastres

- Los planes de continuidad, si existen, apenas consideran escenarios cibernéticos.
- Se consideran algunos escenarios, pero sin análisis estructurado.
- Ciberseguridad está integrada en los planes y se realizan simulacros específicos.
- Existe un enfoque integral de resiliencia, con coordinación entre negocio, TI y ciberseguridad.

F.5. Medición de tiempos de detección y recuperación

- No se miden de forma sistemática.
- Se dispone de estimaciones aproximadas para incidentes recientes.
- Se miden Tiempos Medios de Detección (MTTD) y de Respuesta/Recuperación (MTTR).
- Se miden, se comparan contra objetivos y se utilizan para priorizar mejoras.

8. Bloque G – Capacidades, cultura y formación

G.1. Recursos humanos dedicados a ciberseguridad

- No hay roles específicos; "todo el mundo" se ocupa de todo.
- Existe al menos una persona dedicada, pero con múltiples sombreros.
- Existe un equipo definido de ciberseguridad.
- Existe un equipo estructurado y multidisciplinar (seguridad, riesgo, cumplimiento, continuidad, etc.).

G.2. Nivel de competencias del equipo de ciberseguridad

(auto-evaluación)

- Básico: conocimiento principalmente operativo y reactivo.
- Intermedio: mezcla de perfiles técnicos y de gestión de riesgos.
- Avanzado: capacidades sólidas en gestión de riesgos, arquitectura, respuesta a incidentes.
- Excelente: equipo con experiencia demostrada, certificaciones reconocidas y colaboración activa en foros sectoriales.

G.3. Programas de concienciación y formación en ciberseguridad para el conjunto de la plantilla

- Formación puntual cuando ocurre algo grave.
- Formación anual de cumplimiento mínimo (por ejemplo, e-learning obligatorio).
- Programa estructurado con campañas periódicas y contenidos adaptados a roles.
- Cultura integrada: la ciberseguridad se trabaja de forma continua y visible, con indicadores de participación y efectividad.

G.4. Sensibilización específica de la alta dirección y del órgano de gobierno

- Escasa; se habla de ciberseguridad solo cuando aparece en prensa.
- Sesiones informativas puntuales.
- Programas específicos de formación y simulación para alta dirección.
- La alta dirección actúa como sponsor visible y activo de la ciberseguridad.

G.5. Cultura de reporte de incidentes y errores

- Predomina el miedo a "matar al mensajero".
- Se reportan incidentes graves, pero existe reticencia a compartir errores.
- Se fomenta el reporte temprano, con enfoque de aprendizaje.
- Existe una cultura explícita de seguridad psicológica y mejora continua.

9. Bloque H – Alineamiento normativo y marcos de referencia

H.1. Nivel de alineamiento con el Esquema Nacional de Seguridad (ENS), cuando aplica

- No aplica (organización fuera del ámbito ENS).
- Se está comenzando el camino; análisis de brecha inicial.
- Existe un plan de adecuación en marcha.
- Alto grado de adecuación, con auditorías periódicas y mejora continua.

H.2. Cumplimiento de obligaciones derivadas de NIS2 (para operadores esenciales e importantes)

- No aplica.
- Se tienen identificadas las obligaciones, pero sin plan detallado.
- Existe plan de cumplimiento en ejecución.
- Cumplimiento avanzado, con revisión periódica y coordinación con la autoridad competente.

H.3. Alineamiento con normas y marcos internacionales

(marque los que apliquen y el grado de implementación)

Para cada marco, indique:

- 0 = No considerado.
- 1 = Considerado pero no implantado.
- 2 = Implantación parcial.
- 3 = Implantación avanzada / certificación.

Marcos:

- ISO/IEC 27001.
- ISO/IEC 27005.
- ISO 22301 (continuidad de negocio).
- NIST Cybersecurity Framework.
- OCTAVE (cualquier variante).
- Otros (especificar).

H.4. Protección de datos personales (RGPD y normativa nacional)

- Enfoque reactivo; solo se actúa ante incidentes o requerimientos.
- Cumplimiento básico (políticas y textos legales), con huecos prácticos.
- DPO activo, evaluaciones de impacto (EIPD) y controles técnicos alineados.
- Integración plena entre protección de datos y gestión de riesgos de ciberseguridad.

10. Bloque I – Métricas, IGM y ROI de la ciberseguridad

I.1. Existencia de indicadores clave (KPI/KRI) de ciberseguridad definidos y aprobados

- No existen indicadores formales; se sobrevive a base de percepciones.
- Se utilizan indicadores técnicos dispersos (logs, tickets, etc.).
- Existe un cuadro de mando de indicadores técnicos y de proceso.
- Existe un cuadro de mando equilibrado, con indicadores técnicos, de negocio y de riesgo.

I.2. Uso de un índice de madurez global de ciberseguridad (IGM) u otro índice equivalente

- No se utiliza ningún índice de madurez.
- Se utiliza un índice ad-hoc sin metodología formal.
- Se utiliza un modelo de madurez estructurado (por ejemplo, basado en NIST CSF, OCTAVE, ENS u otros).
- Se utiliza un índice formal, revisado periódicamente y compartido con la alta dirección.

I.3. Frecuencia de cálculo y revisión del IGM o índice equivalente

- No se calcula.
- De forma esporádica (por ejemplo, antes de auditorías).
- Anualmente.
- Semestral o trimestralmente, con planes de acción asociados.

I.4. Enfoque para estimar el retorno de la inversión (ROI) en ciberseguridad

- No se calculan ROI ni métricas equivalentes; la seguridad es vista como un coste hundido inevitable.
- Se utilizan aproximaciones cualitativas (por ejemplo, escenarios de pérdida evitada).
- Se utilizan fórmulas de Return on Security Investment (ROSI) basadas en riesgo evitado.
- Se combinan métricas de ROSI, reducción de riesgo y beneficios intangibles (confianza, cumplimiento, habilitación de negocio).

I.5. Uso de métricas operativas avanzadas

(marque todas las que se midan de forma sistemática)

- Tiempo medio de detección (MTTD).
- Tiempo medio de respuesta / recuperación (MTTR).
- Reducción de incidentes significativos año a año.
- Tasa de parcheo de vulnerabilidades críticas dentro de plazo objetivo.
- Tasa de clic en simulaciones de phishing / evolución de la concienciación.
- Otros (especificar).

11. Bloque J – Percepción global y prioridades

J.1. Percepción global del nivel de madurez en ciberseguridad de su organización

- Muy bajo: sobrevivimos a base de reflejos y buena suerte.
- Bajo: vamos reaccionando, pero sin una estructura sólida.
- Medio: contamos con una base razonable, aunque con huecos relevantes.
- Alto: tenemos un programa robusto, en mejora continua.
- Muy alto: somos referencia en nuestro sector y compartimos buenas prácticas.

J.2. Principales barreras para mejorar la ciberseguridad en su organización

(marque hasta tres)

- Presupuesto insuficiente.
- Falta de personal cualificado.
- Falta de apoyo de la alta dirección.
- Complejidad regulatoria y documental.
- Dependencias de terceros y cadena de suministro.
- Cultura organizativa resistente al cambio.
- Otras (especificar).

J.3. Prioridades de mejora para los próximos 24 meses (marque hasta tres)

- Fortalecer la gobernanza y el alineamiento con negocio.
- Mejorar la gestión de activos y vulnerabilidades.
- Reforzar la detección y respuesta a incidentes.
- Impulsar la formación y la cultura de ciberseguridad.
- Acelerar la adecuación a ENS/NIS2 y otros marcos.
- Mejorar la analítica de riesgos, métricas y ROI.

J.4. Comentarios adicionales

- Espacio abierto para compartir preocupaciones, ideas brillantes o advertencias proféticas que no encajan en respuestas tipo.

Fin del modelo de encuesta integral. Gracias por dedicar tiempo a describir cómo se sostiene, en realidad, la seguridad de su organización.